

Virvelle S.r.l. – Società Benefit 2025. All rights reserved. Confidential and proprietary

virvelle

UC2 · LEZIONE 10 DI 14

Rispondere all'incidente: le prime ore

Dichiarare, contenere, preservare le prove: il piano delle prime due ore

Docente: Singh Simranjit

virvelle

01. Apertura

Dove siamo nel percorso

LEZIONI 1–3
Reti aziendali
Capire che cosa c'è da difendere

LEZIONI 4–7
Log e monitoraggio
Leggere le tracce lasciate dai sistemi

LEZIONI 8–9
Il SOC
Chi sorveglia, con quali ruoli e strumenti

LEZIONI 10–12 · QUI
Incidenti
Rilevare, analizzare, rispondere

LEZIONI 13–14
Simulazioni
Mettere tutto insieme su casi realistici

Dall'indagine alla risposta: adesso bisogna agire.

virvelle

01. Apertura

RIPASSO · 4 MINUTI

Ripasso: vero o falso?

1. Il livello 1 del SOC smista gli allarmi; il livello 2 indaga.
2. Una timeline raccoglie gli eventi in ordine, ciascuno con la sua prova.
3. Un hash è l'impronta digitale di un file.
4. Se dei dati personali escono, non c'è nessun obbligo di legge.
5. MITRE ATT&CK è un dizionario pubblico delle mosse degli attaccanti.

Scrivete in chat cinque lettere, per esempio V F V F V.

virvelle

01. Apertura

Il compito a casa: com'è andata?

Che cosa avete fatto	Che cosa avete visto	Oggi serve
Completare l'indagine	La storia dall'email al riscatto	Il punto di partenza di oggi
Cercare T1566 su ATT&CK	Le sotto-tecniche del phishing	A capire come chiudere la porta
Scrivere la regola della scoperta	Grandi dati in uscita, di notte	Lo ritroverete nel ripristino
Che cosa fare nelle prossime 24 ore	…	È esattamente la lezione di oggi

«Che cosa dovrebbe fare Valmora nelle prossime 24 ore?» Oggi rispondiamo.

virvelle

01. Apertura

Dove eravamo rimasti

L'INDAGINE

Il quadro è chiaro

Ransomware su SRV-FILE-01, 1.870 file cifrati, e 1,2 GB di dati usciti verso l'estero.

COME SONO ENTRATI

Una password rubata

Phishing a l.ferrari, poi un account amministratore creato di nascosto: supporto.it.

LO STATO

Il server è isolato

Alle 10 l'IT ha staccato SRV-FILE-01 dalla rete. Il fuoco, per ora, è circoscritto.

Sappiamo che cosa è successo. Adesso la domanda è: che cosa facciamo?

virvelle

DOMANDA DI PARTENZA

Il server è isolato. E adesso?

Sono le 10:15 di giovedì. Avete la timeline in mano. Scrivete in chat: qual è la PRIMA cosa che fareste?

virvelle

01. Apertura

RISCALDAMENTO · 3 MINUTI

Vero o panico?

1. «Spegniamo subito tutti i server, per sicurezza.»
2. «Paghiamo il riscatto, così recuperiamo i file.»
3. «Cancelliamo l'account supporto.it e cambiamo la password di l.ferrari.»
4. «Non diciamo niente a nessuno, per non fare brutta figura.»

Per ognuna scrivete in chat: GIUSTO, SBAGLIATO o DIPENDE.

virvelle

01. Apertura

Il programma di oggi

Inizio	Attività	Durata
0:00	Apertura e ripasso	15 minuti
0:15	Teoria: che cos'è la risposta e il suo ciclo	35 minuti
0:50	Teoria: le prime ore e il contenimento	40 minuti
1:30	Strumenti: il registro dell'incidente	20 minuti
1:50	Pausa	30 minuti
2:20	Strumenti: la simulazione e le decisioni	40 minuti
3:00	Pratica a gruppi: le prime due ore di Valmora	40 minuti
3:40	Presentazioni e discussione	12 minuti
3:52	Chiusura	8 minuti

virvelle

01. Apertura

Che cosa saprete fare alla fine

CONOSCERE

Il ciclo della risposta

Le fasi di un incidente, dalla preparazione alle lezioni apprese.

DECIDERE

Nelle prime ore

Dichiarare, formare la squadra, contenere senza distruggere le prove.

REGISTRARE

Ogni azione

Tenere il registro dell'incidente: che cosa, quando, chi ha deciso.

Oggi imparate a tenere la testa fredda quando tutto va storto.

virvelle

02. TEORIA · PRIMA PARTE

Che cos'è la risposta all'incidente

Un modo organizzato di affrontare un attacco in corso: passi definiti, ruoli chiari, decisioni prese in anticipo, non nel panico.

02. Teoria

Evento, allarme, incidente

EVENTO E ALLARME

Succede di continuo

Un accesso, una connessione, un allarme del SIEM.

La maggior parte non è niente: rumore, falsi positivi.

Li gestisce il SOC, ogni giorno.

INCIDENTE

Un attacco reale, con impatto

Dati cifrati, dati rubati, un sistema compromesso.

Richiede una risposta coordinata, non un solo analista.

Attiva la squadra di risposta.

Non tutti gli allarmi sono incidenti. Ma ogni incidente nasce da un allarme che qualcuno ha preso sul serio.

virvelle

02. Teoria

Che cosa NON è la risposta all'incidente

NON È L'INDAGINE

Quella è venuta prima

Il livello 2 ha già capito che cosa è successo. Ora si agisce su quella conoscenza.

NON È L'INFORMATICA

Da sola non basta

Servono decisioni di business, comunicazione, scelte legali. Non solo tecnica.

NON È IMPROVVISARE

Si prepara prima

Nel momento della crisi si segue un piano scritto, non si inventa.

L'indagine capisce. La risposta agisce. E le decisioni migliori si prendono prima della crisi.

virvelle

02. Teoria

Quanto è grave? I livelli di un incidente

Livello	Esempio	Chi coinvolge
Basso	Un PC infettato da un programma indesiderato, già isolato	Il SOC e l'IT
Medio	Un account compromesso, senza danni gravi	SOC, IT, il responsabile
Alto	Dati rubati, un server compromesso	La squadra di risposta, la direzione
Critico	Ransomware diffuso, azienda ferma	Tutti, più autorità e, a volte, esterni

Più l'incidente è grave, più sale il livello di chi decide. Valmora è al livello critico.

virvelle

02. Teoria

I tipi di incidente più comuni

Tipo	Che cos'è	La risposta punta a
Ransomware	I file vengono cifrati, si chiede un riscatto	Contenere e ripristinare dai backup
Furto di dati	Dati copiati e portati all'esterno	Capire che cosa è uscito, notificare
Account compromesso	Qualcuno entra con credenziali altrui	Bloccare l'account, cambiare le password
Frode via email (BEC)	Un finto dirigente ordina un bonifico	Fermare il pagamento, avvisare la banca
Blocco del servizio (DDoS)	Un sito viene sommerso e reso irraggiungibile	Filtrare il traffico, reggere l'ondata

Tipi diversi, stesse fasi: cambia che cosa si contiene e che cosa si ripristina.

virvelle

02. TEORIA · IL CICLO

Il ciclo di vita della risposta

Un attacco non si affronta a caso: si seguono fasi precise, sempre le stesse, in ordine. È lo stesso schema in tutto il mondo.

virvelle

02. Teoria

Le quattro fasi (lo standard NIST)

1. Preparazione
prima che accada

→

2. Rilevamento e analisi
capire che cosa

→

3. Contenimento, eradicazione, ripristino
agire

→

4. Attività post-incidente
imparare

Prima: la preparazione

Piano, squadra, strumenti, backup: tutto pronto quando serve.

Durante: capire e agire

Le lezioni 8-9 erano il rilevamento. Oggi comincia l'azione.

Dopo: imparare

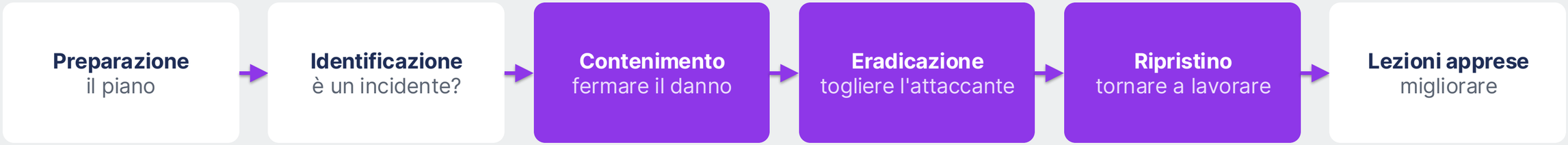
Ogni incidente insegna qualcosa. Che torna nella preparazione.

È un cerchio: si finisce dove si è cominciato, un po' più forti.

virvelle

02. Teoria

Le sei fasi, in dettaglio



Fatte (lez. 1–9)

Preparazione e identificazione: difendersi, sorvegliare, indagare.

Oggi (lez. 10)

Contenimento: la prima mossa quando l'incidente è confermato.

Lez. 11 e 12

Eradicazione e ripristino, poi la comunicazione e le lezioni apprese.

Oggi siamo al terzo passo: il danno è reale, va fermato subito.

virvelle

02. Teoria

Perché un ordine fisso, e non una lista

PRIMA FERMARE

Poi riparare

Ripristinare i file mentre l'attaccante è ancora dentro non serve: li ricifra.

PRIMA CAPIRE

Poi togliere

Eradicare senza aver capito come è entrato lascia la porta aperta per la prossima volta.

OGNI FASE

Prepara la dopo

Il contenimento preserva le prove che servono all'eradicazione e alla notifica.

L'ordine non è burocrazia: saltare una fase fa ricominciare da capo, o peggio.

virvelle

02. Teoria

La preparazione: che cosa serve PRIMA

Che cosa	A che serve	Valmora ce l'aveva?
Un piano di risposta scritto	Sapere chi fa cosa, senza pensarci	No: ecco perché è nel panico
Una squadra e i contatti	Raggiungere le persone giuste, subito	In parte
Backup separati e testati	Ripristinare senza pagare	Da verificare (lezione 11)
Log centralizzati (SIEM)	Ricostruire che cosa è successo	Sì: per questo c'è una timeline

La preparazione non si improvvisa durante l'incendio. O c'è, o manca quando serve.

virvelle

02. Teoria

Il piano di risposta (IRP)

CHE COS'È

Il copione della crisi

Un documento che dice, per ogni tipo di incidente, chi fa cosa e in quale ordine.

CHE COSA CONTIENE

Ruoli e procedure

Chi dichiara, chi decide, chi comunica, chi chiamare di notte, e i playbook (lezione 8).

PERCHÉ SCRITTO

Nel panico non si ragiona

Alle 3 di notte, con l'azienda ferma, si esegue. Non si inventa.

Un piano scritto trasforma il panico in una lista di cose da fare.

virvelle

CURIOSITÀ

Chi si prepara si riprende prima, e spende meno.

I rapporti di settore mostrano da anni che le aziende con un piano di risposta collaudato contengono gli incidenti più in fretta e con costi molto inferiori.

virvelle

02. Teoria

Chi dichiara un incidente

CHI

Una persona indicata

Nel piano è scritto chi ha l'autorità di dire «questo è un incidente»: di solito il responsabile del SOC.

QUANDO

Meglio una volta di troppo

Dichiarare attiva la squadra. Un allarme grave dubbio si dichiara: si può sempre chiudere dopo.

CHE COSA CAMBIA

Scatta il piano

Da quel momento non è più lavoro di routine: partono i ruoli, il registro, le comunicazioni.

Dichiarare un incidente non è un fallimento: è l'inizio della soluzione.

virvelle

02. Teoria

La squadra di risposta: chi fa cosa

Ruolo	Che cosa fa	Nell'incidente di Valmora
Coordinatore	Guida la risposta, prende le decisioni	Il responsabile del SOC o dell'IT
Analisti	Contengono, indagano, eradicano	Il SOC, lezioni 8-9
IT e sistemisti	Isolano, bloccano, ripristinano	Chi gestisce i server
Comunicazione	Avvisa dentro e fuori	Direzione, a volte un portavoce
Legale e DPO	Decide su autorità e notifiche	Con la direzione (lezione 12)

Non serve essere in tanti. Serve che ogni ruolo abbia un nome, deciso prima.

virvelle

02. Teoria

La war room

CHE COS'È

Il centro della crisi

Un posto, fisico o virtuale, dove la squadra si riunisce e coordina la risposta.

A CHE SERVE

Decisioni rapide

Tutti insieme, con le informazioni aggiornate: niente catene di email che rallentano.

UNA REGOLA

Un canale a parte

Se la rete o la posta sono compromesse, si comunica altrove: telefono, chat separata.

Se l'attaccante è in casa, non si pianifica la difesa a voce alta.

virvelle

02. Teoria

MINI ESERCIZIO · 3 MINUTI

Quale fase del ciclo?

1. Scrivere il piano di risposta e provarlo con un'esercitazione.
2. Capire, dai log, che un account è stato rubato.
3. Staccare dalla rete il server che sta cifrando i file.
4. Ripristinare i file da un backup pulito.
5. Scrivere che cosa si è imparato e aggiornare le regole.

Scrivete: PREPARAZIONE, IDENTIFICAZIONE, CONTENIMENTO, RIPRISTINO o LEZIONI.

virvelle

02. Teoria

Mini glossario, prima parte

Termine	In una riga
Incidente	Un attacco reale con impatto, che richiede una risposta coordinata
Ciclo di vita	Le fasi della risposta, in ordine fisso, da ripetere a ogni incidente
Dichiarare	L'atto formale che attiva la squadra e il piano
IRP	Il piano di risposta scritto: ruoli, procedure, contatti
CSIRT / IRT	La squadra di risposta agli incidenti
War room	Il centro di coordinamento della crisi

virvelle

02. TEORIA · SECONDA PARTE

Le prime ore: il contenimento

L'obiettivo non è riparare, non ancora. È fermare l'emorragia: impedire che il danno cresca, mentre si preserva tutto ciò che servirà dopo.

virvelle

02. Teoria

L'obiettivo delle prime ore

FERMARE

La crescita del danno

Impedire che l'attaccante cifri altri file, rubi altri dati, raggiunga altri sistemi.

PRESERVARE

Le prove

Non distruggere ciò che serve per capire, per eradicare e per la notifica di legge.

NON PEGGIORARE

Con mosse avventate

Spegnere, cancellare, riavviare: gesti istintivi che spesso fanno più male che bene.

Contenere è fermare il danno senza distruggere ciò che serve per capirlo.

virvelle

02. Teoria

Contenimento a breve e a lungo termine

A BREVE TERMINE

Tamponare, subito

Isolare il sistema colpito dalla rete, bloccare gli account usati.

Grezzo ma immediato: ferma l'emorragia in minuti.

Minuti. Priorità: fermare il danno.

A LUNGO TERMINE

Mettere in sicurezza

Una soluzione che regge per giorni, mentre si prepara l'eradicazione.

Per esempio: ricostruire un sistema pulito accanto a quello isolato.

Ore o giorni. Priorità: stabilità.

Prima il laccio emostatico, poi la medicazione. Nell'ordine giusto.

virvelle

02. Teoria

Le opzioni di contenimento

Azione	Che cosa fa	Attenzione
Isolare dalla rete	Il sistema resta acceso ma non comunica	La migliore: ferma e preserva
Bloccare un account	L'attaccante non può più usarlo	Prima verificate che sia davvero lui
Bloccare un IP o un dominio	Taglia il canale verso l'attaccante	L'attaccante può cambiarlo
Spegnere il sistema	Blocco totale e immediato	Distrugge le prove in memoria
Staccare la rete aziendale	Ferma tutto, in casi estremi	Ferma anche l'azienda

Isolare, non spegnere: è la regola d'oro del contenimento.

virvelle

02. Teoria

PASSO 1 DI 4

Isolare un sistema, passo per passo

Decidere
vale la pena?

→

Isolare
staccare la rete

→

Verificare
è davvero isolato?

→

Annotare
nel registro

1. Decidete se isolare

Il sistema fa danni o potrebbe farne? A Valmora sì: il server cifrava i file e mandava dati fuori. Si isola.

A VALMORA

```
Danno in corso?
→ isolare
```

virvelle

02. Teoria

PASSO 2 DI 4

Isolare un sistema, passo per passo

Decidere
vale la pena?

→

Isolare
staccare la rete

→

Verificare
è davvero isolato?

→

Annotare
nel registro

2. Isolate, senza spegnere

Con l'EDR (un clic), o staccando il cavo di rete, o togliendo le regole del firewall. Il sistema resta acceso: la memoria e i file restano come prove.

A VALMORA

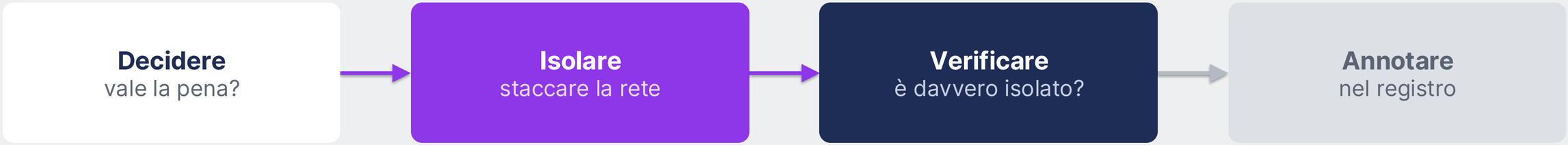
EDR, cavo, firewall
NON spegnere

virvelle

02. Teoria

PASSO 3 DI 4

Isolare un sistema, passo per passo



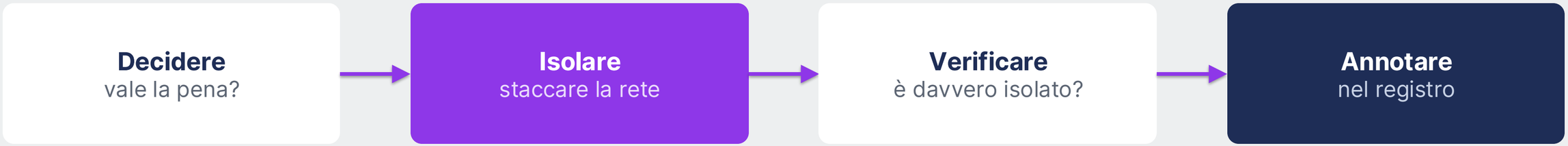
3. Verificate che sia isolato

Controllate che non comunichi più: nessuna connessione in uscita nel firewall, nessun accesso riuscito.

A VALMORA

```
Firewall: niente uscite
Accessi: niente login
```

Isolare un sistema, passo per passo



4. Annotate tutto

Ora esatta, chi ha deciso, come. Nel registro dell'incidente. Servirà per la ricostruzione e per la notifica.

A VALMORA

```
Ora, chi, come
nel registro
```

virvelle

02. Teoria

Il dilemma: spegnere o isolare?

SE SPEGNI

Fermi tutto, ma

Il blocco è totale e immediato. Però la memoria del computer si cancella: lì ci sono prove preziose.

SE ISOLI

Fermi il danno e

Tieni il sistema acceso e «congelato»: la memoria, i processi, le connessioni restano da esaminare.

LA REGOLA

Isolare, quasi sempre

Si spegne solo se non si può isolare, o se spegnere è l'unico modo per fermare un danno fisico.

Spegnere un computer compromesso è come buttare l'arma del delitto prima dei rilievi.

virvelle

02. Teoria

Contenere senza distruggere le prove

Fare	Non fare	Perché
Isolare dalla rete	Spegnere	La memoria contiene prove
Fotografare lo schermo	Cancellare i file sospetti	Servono per capire e per la legge
Copiare i log subito	Riavviare «per pulire»	Il riavvio cancella le tracce
Annotare ogni azione con l'ora	Lavorare a memoria	Senza registro, non si ricostruisce

Sotto pressione, l'istinto dice «pulisci». Il metodo dice «congela e annota».

virvelle

02. Teoria

La catena di custodia delle prove

CHE COS'È

Chi ha toccato cosa

Un registro di ogni prova: chi l'ha raccolta, quando, dove è conservata, chi vi ha accesso.

A CHE SERVE

Validità legale

Se l'incidente finisce in tribunale o davanti al Garante, le prove valgono solo se tracciate.

COME

Copie, non originali

Si lavora su copie; l'originale si conserva intatto e sigillato.

Una prova che non si sa chi ha toccato, quando e come, davanti a un giudice non vale nulla.

virvelle

CURIOSITÀ

La prima mossa istintiva è quasi sempre spegnere. Ed è quasi sempre sbagliata.

Spegnere un computer compromesso cancella la memoria, dove spesso si nasconde la chiave per decifrare i file senza pagare.

virvelle

02. Teoria

PASSO 1 DI 4

Contenere l'incidente di Valmora

Isolare
il server

→

Bloccare
gli account

→

Tagliare
i canali

→

Cercare
altri PC

1. Isolare SRV-FILE-01

Fatto alle 10 dall'IT: staccato dalla rete, ma lasciato acceso. La prima mossa, giusta.

AZIONE

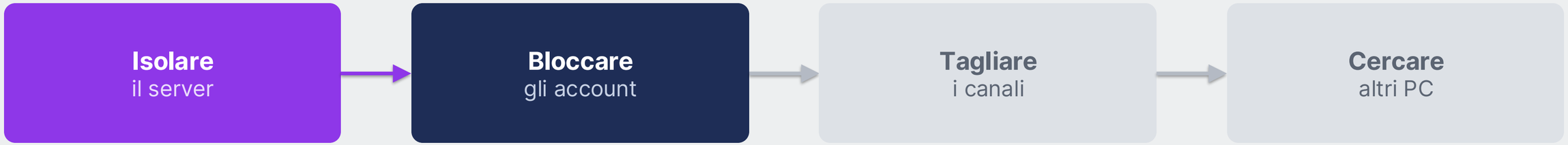
`Server isolato acceso, congelato`

virvelle

02. Teoria

PASSO 2 DI 4

Contenere l'incidente di Valmora



2. Bloccare gli account compromessi

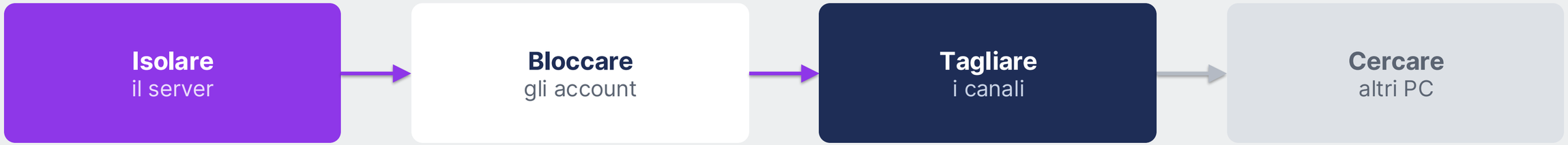
Disattivare supporto.it (creato dall'attaccante) e l.ferrari (rubato). Chiudere tutte le loro sessioni aperte.

AZIONE

```
supporto.it: via
l.ferrari: bloccato
```

virvelle

Contenere l'incidente di Valmora



3. Tagliare i canali dell'attaccante

Bloccare sul firewall gli IP 103.75.118.9 e 91.219.237.44, e il dominio del phishing sulla posta.

AZIONE

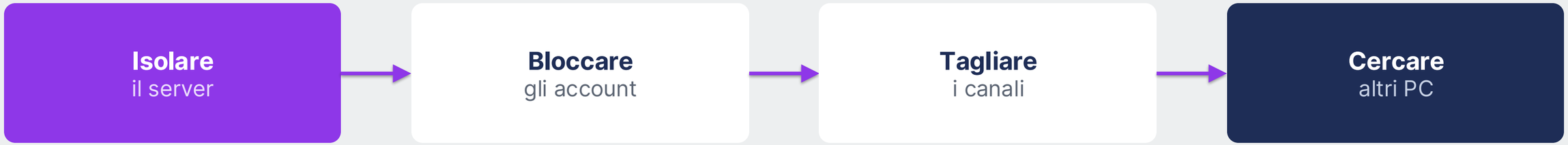
`IP e dominio bloccati`

virvelle

02. Teoria

PASSO 4 DI 4

Contenere l'incidente di Valmora



4. Cercare altri sistemi colpiti

L'attaccante aveva i diritti di amministratore: ha toccato solo SRV-FILE-01? Si controllano gli altri server e PC.

AZIONE

```
Altri server?
Altri PC?
```

virvelle

02. Teoria

Bloccare gli account e gli accessi

GLI ACCOUNT

Disattivare, non cancellare

Disattivare blocca l'accesso ma conserva le prove. Cancellare le distrugge.

LE SESSIONI

Chiudere quelle aperte

Un account bloccato ma con una sessione già aperta può ancora agire: vanno chiuse.

LE PASSWORD

Cambiarle, con la MFA

Dopo aver bloccato, nuove password e un secondo fattore. Se non c'era, è ora di metterlo.

Togliere all'attaccante le chiavi è spesso più efficace che chiudere le porte.

virvelle

02. Teoria

Nelle prime ore: che cosa comunicare, a chi

A chi	Che cosa	Quando
La direzione	C'è un incidente grave, ecco i fatti noti	Subito
La squadra di risposta	Il quadro e i ruoli	Subito, nella war room
Chi usa i sistemi colpiti	«Non usate il server, lavorate così»	Appena possibile
Il DPO e il legale	Potrebbe esserci un furto di dati	Entro poche ore (lezione 12)
Autorità, clienti, pubblico	Solo quando e come deciso	Più avanti, con cautela

Nelle prime ore si parla dentro. Fuori si parla dopo, con la direzione e il legale.

virvelle

02. Teoria

La comunicazione interna: una voce sola

UN SOLO CANALE

Per non fare caos

Le informazioni passano dalla war room. Non ognuno che dice la sua in giro per l'azienda.

FATTI, NON VOCI

Solo ciò che è certo

«Il server è isolato» è un fatto. «Ci hanno rubato tutto» è una voce che crea panico.

UN CANALE SICURO

Se la rete è compromessa

Telefono o chat separata: l'attaccante potrebbe leggere la posta aziendale.

In una crisi, dieci voci diverse fanno più danni di un'ora di silenzio.

virvelle

02. Teoria

Quando chiamare gli esterni

GLI AIUTI TECNICI

Chi può intervenire

Un SOC esterno, una società di risposta agli incidenti, la polizia postale.

Per Valmora, probabilmente un consulente esterno.

Averne i contatti pronti.

GLI OBBLIGHI

Chi va avvisato per legge

Il Garante (dati personali), l'ACN (per chi rientra nella NIS2).

Con tempi stretti: 72 ore, 24 ore. Lezione 12.

Decide la direzione con il DPO.

Gli aiuti si chiamano per scelta; le autorità si avvisano per obbligo. Entrambi, meglio se previsti.

virvelle

02. Teoria

Pagare il riscatto?

LA REGOLA

Sconsigliato

Le autorità (anche l'ACN) sconsigliano di pagare: finanzia i criminali e non garantisce nulla.

NON GARANTISCE

Spesso non funziona

Una parte di chi paga non riceve la chiave, o la riceve e i file restano danneggiati.

LA VERA DIFESA

Un backup pulito

Chi ha un backup separato e testato non deve nemmeno porsi la domanda. È il tema della lezione 11.

La risposta migliore al «paga o perdi tutto» è averci già pensato: un backup che l'attaccante non tocca.

virvelle

02. Teoria

Gli errori più comuni delle prime ore

IL PANICO

Agire a caso

Spegnere tutto, cancellare, riavviare: gesti istintivi che distruggono prove e peggiorano.

L'ESITAZIONE

Non dichiarare

Per paura di esagerare si aspetta, e il danno cresce. Meglio dichiarare e poi ridimensionare.

IL SILENZIO

Non annotare

Si agisce senza scrivere. Poi nessuno ricorda l'ordine delle cose, e la ricostruzione è impossibile.

Panico, esitazione, silenzio: i tre nemici delle prime ore. Il piano li batte tutti e tre.

virvelle

02. Teoria

Tenere la testa fredda

RALLENTARE

Per andare più veloci

Trenta secondi per pensare prima di agire evitano l'errore che costa ore. La fretta è nemica.

UNA COSA ALLA VOLTA

Seguire la lista

Con la checklist non si decide tutto insieme: si spunta un passo per volta, con ordine.

CHIEDERE AIUTO

Non è una debolezza

Nessuno gestisce una crisi da solo. La squadra, e gli esterni, esistono per questo.

Sotto pressione non serve essere più veloci: serve essere più ordinati.

virvelle

02. Teoria

MINI ESERCIZIO · 3 MINUTI

Contenere: giusto o sbagliato?

1. Isolare dalla rete il server che sta cifrando i file.
2. Spegnere subito il server per fermare tutto.
3. Cancellare l'account dell'attaccante per toglierlo di mezzo.
4. Bloccare sul firewall l'indirizzo verso cui escono i dati.
5. Riavviare il server «per pulirlo» prima di indagare.

Scrivete GIUSTO o SBAGLIATO, e per uno spiegate perché.

virvelle

02. Teoria

Mini glossario, seconda parte

Termine	In una riga
Contenimento	Fermare la crescita del danno senza distruggere le prove
Isolare	Staccare un sistema dalla rete lasciandolo acceso
Eradicazione	Togliere l'attaccante e chiudere la falla (lezione 11)
Analisi forense	Esaminare un sistema compromesso senza alterarlo
Catena di custodia	Il registro di chi ha toccato ogni prova, quando e come
Registro dell'incidente	Il diario di tutte le azioni e decisioni, con gli orari

virvelle

03. STRUMENTI

Il registro dell'incidente

Lo strumento più importante delle prime ore non è tecnico: è un diario. Chi ha deciso che cosa, quando, e perché.

virvelle

03. Strumenti

Gli strumenti di oggi

Strumento	A che cosa serve	Chi lo usa oggi
Il registro dell'incidente	Annotare ogni azione e decisione, con l'ora	Tutti, a gruppi
L'EDR	Isolare un sistema dalla rete con un clic	Ricostruzioni
La checklist di contenimento	Non dimenticare nessun passo	Tutti
La war room (virtuale)	Coordinare la squadra	La classe, nella pratica

Lo strumento che salva la risposta non è un software: è un diario tenuto bene.

virvelle

03. Strumenti

La risposta agli incidenti come lavoro

Incident responder
Chi coordina e gestisce le crisi: un ruolo molto richiesto e ben pagato.

Si lavora in squadra
Mai da soli: coordinatore, analisti, IT, legale. E spesso con esterni.

Serve sangue freddo
Più del genio tecnico conta la calma e il metodo sotto pressione.

Si impara facendo
Esercitazioni, tabletop e simulazioni come quella di oggi: così ci si prepara.

Le certificazioni
Esistono percorsi dedicati alla risposta agli incidenti e all'analisi forense.

Da dove si parte
Spesso dal SOC: chi ha fatto triage e indagine conosce già metà del lavoro.

Dal SOC alla risposta agli incidenti: un percorso naturale, dove la calma vale più del codice.

virvelle

03. Strumenti

Il registro dell'incidente

Che cos'è

Un documento, spesso un semplice foglio di calcolo, dove si annota ogni azione della risposta, in ordine di tempo.

A cosa serve

Ricostruire che cosa è stato fatto, dimostrarlo a chi di dovere, e non dimenticare nulla nella fretta.

Quando si usa

Dal momento in cui si dichiara l'incidente, fino alla chiusura.

COME SI USA

1. Si apre quando si dichiara l'incidente.
2. Ogni riga: ora, chi, che cosa ha fatto o deciso, perché.
3. Si scrive subito, non «dopo»: dopo si dimentica.
4. Si conserva: diventa la base del post-mortem e della notifica.

virvelle

03. Strumenti

Il registro: che cosa vedrete

Registro incidente INC-2026-014 · Valmora

Ora	Chi	Azione / decisione
10:00	IT	Isolato SRV-FILE-01 dalla rete (acceso)
10:15	Resp. SOC	Dichiarato incidente critico INC-2026-014
10:22	SOC	Disattivati supporto.it e l.ferrari
10:30	IT	Bloccati sul firewall i due IP esteri
10:40	Resp. SOC	Avvisata la direzione e il DPO

… ogni azione, in ordine di tempo, con chi l'ha decisa

1 **L'ora**

Precisa: serve per la ricostruzione.

2 **Chi**

Il nome o il ruolo di chi ha agito.

3 **L'azione**

Che cosa, e tra parentesi il perché.

virvelle

03. Strumenti

Come si scrive una riga del registro

Campo	Che cosa ci va	Esempio
Ora	L'orario esatto	10:00
Chi	Il ruolo o il nome	IT / Mario
Azione o decisione	Che cosa è stato fatto	Isolato SRV-FILE-01 dalla rete
Perché / esito	La motivazione o il risultato	Stava cifrando i file; ora non comunica
Prove	Dove sono i dettagli	Screenshot, export del firewall

Ora, chi, cosa, perché. Cinque secondi per riga, e la ricostruzione è salva.

virvelle

03. Strumenti

PROVA TU · 4 MINUTI

Correggete il registro

1. Riga scritta male: «Abbiamo sistemato il server».
2. Che cosa manca? Riscrivetela completa.
3. I fatti: alle 10:00, l'IT ha isolato SRV-FILE-01 dalla rete.
4. Il motivo: stava cifrando i file e mandando dati fuori.

Scrivete in chat la riga corretta, con tutti i campi.

virvelle

03. Strumenti

L'EDR per il contenimento

COSA FA

Isola con un clic

Dalla console, l'analista stacca un PC dalla rete senza alzarsi: utile se il PC è lontano.

IL VANTAGGIO

Resta raggiungibile

Il sistema è isolato da tutto, tranne che dalla console del SOC: si può ancora esaminare.

A VALMORA

Sarebbe servito

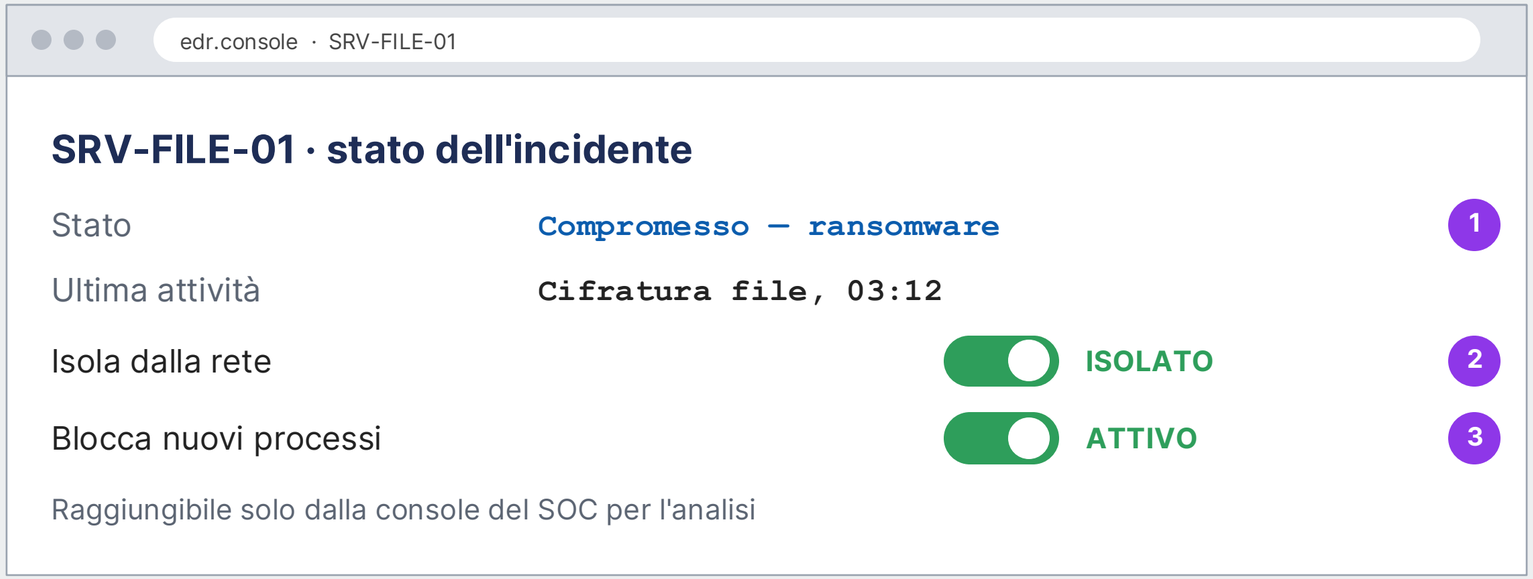
Con un EDR, SRV-FILE-01 si isolava alle 3 di notte in automatico, non alle 10 a mano.

Un EDR trasforma il contenimento da «correre al server» a «un clic dalla scrivania».

virvelle

03. Strumenti

Isolare con l'EDR: che cosa vedrete



1. **Lo stato**
   Che cosa è successo, in chiaro.

2. **L'isolamento**
   Un interruttore: acceso.

3. **La raccolta**
   Il sistema resta esaminabile.

virvelle

03. Strumenti

La checklist di contenimento

Che cos'è

Un elenco scritto dei passi da compiere per contenere, da spuntare uno per uno.

A cosa serve

Non dimenticare nessuna mossa nella fretta e nello stress del momento.

Quando si usa

Appena dichiarato l'incidente, mentre si contiene.

COME SI USA

1. Isolare i sistemi colpiti.
2. Bloccare gli account compromessi e chiudere le sessioni.
3. Bloccare gli indirizzi dell'attaccante (IP, domini).
4. Cercare altri sistemi coinvolti.
5. Annotare tutto nel registro.

virvelle

03. Strumenti

La checklist di contenimento di Valmora

Isolare i sistemi	FATTO — SRV-FILE-01 isolato alle 10:00
Bloccare gli account	FATTO — supporto.it e l.ferrari alle 10:22
Bloccare gli indirizzi	FATTO — due IP e un dominio alle 10:30
Cercare altri sistemi coinvolti	IN CORSO — si controllano gli altri server

virvelle

1:50

Pausa

Si riprende tra 30 minuti con la simulazione: le prime due ore di Valmora, decise da voi.

virvelle

03. STRUMENTI · SECONDA PARTE

La simulazione a tavolino

Un modo per esercitarsi a rispondere senza che ci sia un vero incidente. Si chiama tabletop: si gioca la crisi, a tavolino.

virvelle

03. Strumenti

Che cos'è un tabletop

UNA PROVA

Senza rischi

Si simula un incidente a parole: nessun sistema reale viene toccato, nessun danno vero.

A DECISIONI

Il gruppo sceglie

A ogni svolta, la squadra decide che cosa fare. Poi si vede come evolve la situazione.

PER IMPARARE

Dove sono i buchi

Emergono i punti deboli del piano: chi non sapeva, che cosa mancava, dove si è persa tempo.

Meglio sbagliare a tavolino oggi, che sul server vero alle 3 di notte.

virvelle

03. Strumenti

Le regole del gioco

Regola	In pratica
Si decide a gruppi	Ogni gruppo è la squadra di risposta di Valmora
La situazione evolve	Ogni «inject» aggiunge una novità: voi decidete, io vi dico che cosa succede
Si tiene il registro	Ogni decisione va annotata, con l'ora simulata
Non esiste la risposta perfetta	Conta il ragionamento: perché quella scelta, e in quale ordine
Si può chiedere	«Abbiamo un backup? C'è la MFA?»: chiedere è parte del gioco

virvelle

Come funziona un inject

La situazione
dove siamo

→

L'inject
una novità

→

Voi decidete
che cosa fare

→

L'esito
che cosa succede

1. Partiamo da una situazione

Sono le 10:15, l'incidente è appena stato dichiarato. Ecco che cosa sapete.

ESEMPIO

Ora simulata
10:15

virvelle

Come funziona un inject

La situazione
dove siamo

→

L'inject
una novità

→

Voi decidete
che cosa fare

→

L'esito
che cosa succede

2. Arriva un inject

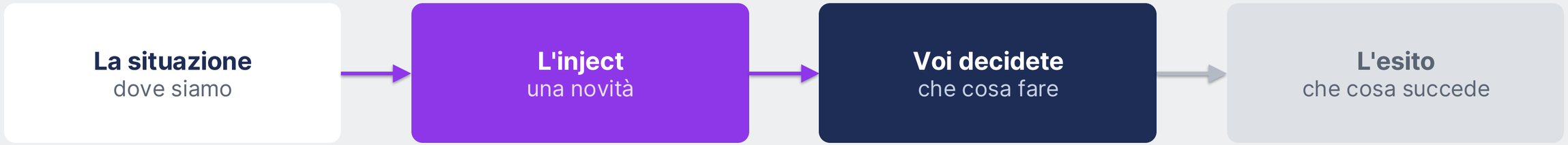
Una novità che cambia le carte: «Un secondo server mostra file .lockd». Che cosa fate?

ESEMPIO

Novità
decidete ora

virvelle

Come funziona un inject



3. Il gruppo decide e annota

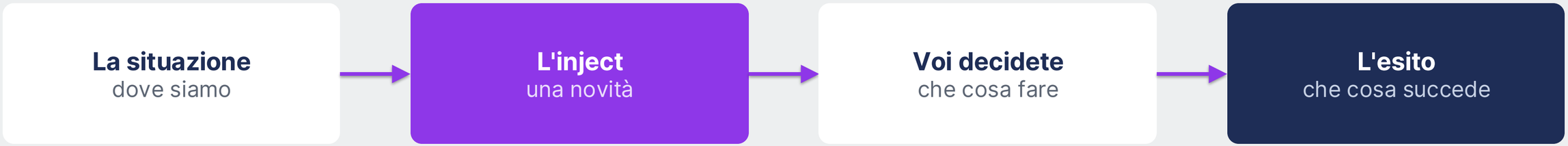
Discutete, scegliete, scrivete la decisione nel registro con l'ora.

ESEMPIO

```
Decisione
nel registro
```

virvelle

Come funziona un inject



4. Vi dico l'esito

La vostra scelta ha una conseguenza, che apre l'inject successivo. E così via.

ESEMPIO

```
Conseguenza
→ nuovo inject
```

virvelle

03. Strumenti

La scheda di decisione

Scheda decisione · Gruppo __ · inject 2

Ora simulata	10:35
La situazione	Secondo server con file .lockd
La nostra decisione	Isolare anche quel server, subito
Perché	Il danno si sta allargando: prima contenere
Chi informiamo	Direzione: l'incidente è più grande

Una scheda per ogni inject, da riportare poi nel registro

1. **La situazione**
   Che cosa è appena successo.
2. **La decisione**
   Che cosa fate, in una riga.
3. **Il perché**
   Il ragionamento dietro la scelta.

virvelle

03. Strumenti

Il metodo di oggi, in quattro passi

N.	Passo	Nella simulazione
1	Capire la situazione	Che cosa so adesso? Che cosa mi manca?
2	Decidere la priorità	Prima fermare il danno, poi il resto
3	Agire e annotare	La decisione, l'ora, il perché, nel registro
4	Comunicare	Chi deve sapere di questa mossa?

Capire, decidere, agire e annotare, comunicare. A ogni svolta della crisi.

virvelle

04. PRATICA · 40 MINUTI

Le prime due ore di Valmora

Gruppi di tre o quattro persone. Siete la squadra di risposta. Sono le 10:15 di giovedì. Comincia la simulazione.

virvelle

04. Pratica

Missione 1: dichiarare e organizzarsi

Che cosa fate	Come	Dove lo scrivete
Dichiarate l'incidente	Dategli un nome e un livello	Registro, prima riga
Assegnate i ruoli	Chi coordina, chi annota, chi comunica	Nel gruppo
Aprite il registro	Con le azioni già fatte dall'IT	Foglio Registro
Decidete dove coordinarvi	War room: quale canale, e perché	Registro

Prima di agire, organizzarsi: un nome, i ruoli, il registro, il canale.

virvelle

04. Pratica

Missione 2: contenere

Che cosa decidete	La domanda	Dove lo scrivete
Gli account compromessi	Bloccare o cancellare? Quali?	Registro
Il server colpito	Spegnere o lasciare isolato?	Registro, con il perché
Gli altri sistemi	Come controllate se sono coinvolti?	Scheda decisione
I canali dell'attaccante	Che cosa bloccate, e dove?	Registro

A ogni mossa: fermo il danno? preservo le prove? È la domanda del contenimento.

virvelle

04. Pratica

Missione 3: il registro e la comunicazione

Che cosa fate	Come	Dove
Completate il registro	Tutte le decisioni, con l'ora	Foglio Registro
Scrivete l'aggiornamento direzione	Tre frasi: cosa, impatto, prossimi passi	Scheda
Decidete chi altro avvisare	Dipendenti? DPO? Esterni?	Registro
Elencate che cosa vi è mancato	Che cosa avreste voluto pronto?	Scheda

Il registro è la prova del vostro lavoro. L'aggiornamento è come lo racconta la direzione.

virvelle

04. Pratica

Che cosa consegna ogni gruppo

Il registro, più tre frasi per la direzione.

Il registro
Ogni azione, con ora, chi, perché.

L'aggiornamento
Che cosa, impatto, prossimi passi.

La lista dei «ci è mancato»
Che cosa avreste voluto pronto.

Il portavoce
Legge l'aggiornamento alla direzione.

Il portavoce leggerà l'aggiornamento come se parlasse al titolare di Valmora.

virvelle

04. Pratica

Un esempio di aggiornamento per la direzione

Che cosa è successo	Un attacco ransomware ha cifrato i file del server principale; alcuni dati sono stati copiati all'esterno.
Lo stato ora	Il server è isolato, gli account dell'attaccante bloccati. Il danno è contenuto, non si allarga.
L'impatto	L'accesso ai file condivisi è sospeso. Stiamo verificando quali altri sistemi siano coinvolti.
I prossimi passi	Ripristino dai backup e valutazione, con il DPO, degli obblighi di notifica entro 72 ore.

virvelle

05. Chiusura

Presentazioni e discussione

1. Avete spento o isolato il server? Perché?
2. Avete cancellato o disattivato gli account dell'attaccante?
3. Come avete controllato se altri sistemi erano coinvolti?
4. Che cosa vi è mancato di più, nelle prime due ore?

virvelle

05. Chiusura

Le decisioni chiave, a confronto

La scelta	L'istinto	La scelta giusta, e perché
Il server	Spegnere	Isolare: ferma il danno e salva le prove in memoria
Gli account	Cancellare	Disattivare: blocca l'accesso ma conserva le prove
Il riscatto	Pagare	Non pagare: si ripristina dai backup (lezione 11)
La comunicazione	Tacere o dire tutto	Fatti a direzione e DPO; fuori, solo come deciso

In ogni svolta, l'istinto sbaglia. Il metodo, deciso a freddo, no.

virvelle

05. Chiusura

Le prime due ore, ricostruite

Ora	Azione	Fase del ciclo
10:00	IT isola SRV-FILE-01 (acceso)	Contenimento
10:15	Dichiarato l'incidente, aperto il registro	Identificazione → risposta
10:22	Disattivati gli account compromessi	Contenimento
10:30	Bloccati IP e dominio dell'attaccante	Contenimento
10:40	Avvisate direzione e DPO	Comunicazione
11:15	Primo aggiornamento alla direzione	Comunicazione

Nessun ripristino, ancora: prima si contiene e si capisce l'estensione.

virvelle

05. Chiusura

Che cosa è andato bene, e che cosa no

BENE

Il contenimento

Isolare invece di spegnere, disattivare invece di cancellare: le prove sono salve.

MALE

La preparazione

Nessun piano, nessuna MFA, backup da verificare: tutto deciso nel panico.

DA FARE

Eradicare e ripristinare

Il server è fermo ma non pulito. Tornare a lavorare è la prossima lezione.

Contenere è solo il primo soccorso. Guarire è un'altra storia: la prossima.

virvelle

05. Chiusura

A mano contro con un piano

	Senza piano (Valmora)	Con un piano di risposta
Il tempo di reazione	Sette ore: scoperto al mattino	Minuti: contenimento in automatico
Le decisioni	Improvvisate nel panico	Già scritte, si eseguono
I ruoli	Confusi	Chiari, assegnati prima
Le prove	Salvate per fortuna	Salvate per procedura

Lo stesso incidente, con un piano, è un problema. Senza, è un disastro.

virvelle

05. Chiusura

Che cosa portiamo a casa

Contenere prima di riparare

Fermare il danno è la prima mossa. Il ripristino viene dopo, mai prima.

Isolare, non distruggere

Si stacca dalla rete, non si spegne. Si disattiva, non si cancella. Le prove servono.

Annotare tutto

Il registro dell'incidente è la differenza tra una risposta e un'improvvisazione.

E la domanda di partenza: adesso si contiene e si annota, senza panico e senza fretta.

virvelle

05. Chiusura

VERIFICA · 2 MINUTI

Verifica finale: vero o falso?

1. La prima cosa da fare con un sistema compromesso è spegnerlo.
2. Contenere significa fermare il danno senza distruggere le prove.
3. Dichiarare un incidente attiva la squadra e il piano di risposta.
4. Gli account dell'attaccante vanno cancellati subito.
5. Il registro dell'incidente si compila mentre si agisce, non alla fine.



Cinque lettere in chat.

virvelle

05. Chiusura

COMPITO

Per chi vuole continuare a casa

1. Immaginate il vostro luogo di lavoro: chi dichiarerebbe un incidente?
2. Scrivete una checklist di contenimento di cinque passi per un PC infetto.
3. Cercate «piano di risposta agli incidenti» e guardate com'è fatto un modello.
4. Pensate: la vostra azienda ha un backup che l'attaccante non può toccare?

Facoltativo. Il quarto punto è il ponte verso la lezione 11.

virvelle

PROSSIMA LEZIONE

Lezione 11: eradicazione e ripristino

L'attaccante è contenuto. Ora va cacciato per davvero, e Valmora deve tornare a lavorare. Ma il backup è pulito?

virvelle

Learn Your Way, Grow With Us.

Virvelle S.r.l. – Società Benefit 2025. All rights reserved. Confidential and proprietary